

Narrativa Explicativa de la Encuesta de Madurez CMMC / NIS2 / ENS

Versión: 1.0

Dirigido a: Responsables de ciberseguridad, TI, riesgo, cumplimiento, y a cualquier persona que haya levantado la mano cuando preguntaron “¿quién sabe de informática?”.

1. Por qué esta encuesta (y por qué ahora)

Vivimos en un ecosistema en el que los incidentes de ciberseguridad en España crecen año tras año, con decenas de miles de casos gestionados por organismos nacionales como INCIBE, y donde la digitalización deja de ser “proyecto” para convertirse en tejido nervioso del país.

Mientras tanto, marcos como **CMMC 2.0**, **NIST SP 800-171/172**, **NIS2**, **ENS** y **DORA** se consolidan como el idioma común de la ciberseguridad moderna, especialmente cuando entran en juego cadenas de suministro internacionales y contratos que exigen algo más que promesas verbales.

La encuesta que tienes entre manos aspira, sin falsa modestia pero con plena consciencia de sus límites, a:

- Ponerle números y matices a la madurez de ciberseguridad de las organizaciones.
- Traducir el lenguaje a veces intimidante de los marcos normativos en preguntas inteligibles.
- Servir de espejo honesto: ni de feria distorsionada ni de filtro embellecedor.

2. El espíritu CMMC en territorio español

El modelo **CMMC** nació, a gran escala, para los contratistas del Departamento de Defensa estadounidense. Su principal virtud es que combina:

- Un conjunto claro de prácticas (lo que hay que hacer).
- Un enfoque de madurez (cómo de integrado y sostenible está todo ello).
- Un sistema de evaluación y scoring (SPRS) que permite comparar y tomar decisiones.

En España, nuestra realidad normativa propia se llama **ENS**, **NIS2**, **DORA**, **RGPD** y compañía. La encuesta no pretende “importar” CMMC tal cual, sino inspirarse en su lógica:

- Estructurar la conversación en bloques temáticos (gobernanza, controles técnicos, resiliencia, cadena de suministro, etc.).
- Traducir los controles en preguntas respondibles sin necesidad de un comité de traductores jurados.
- Permitir comparaciones internas y externas, sin perder de vista la diversidad de sectores y tamaños.

3. Cómo leer las preguntas (y cómo no)

Cada pregunta ha sido diseñada con varias intenciones simultáneas:

1. Identificar si una práctica existe, no existe, o existe “a medias”, con opción de ironía controlada para facilitar la honestidad.
2. Ubicar la práctica en un nivel de madurez: desde el heroísmo improvisado hasta la excelencia aburridamente sistemática.
3. Permitir una puntuación cuantitativa que luego se integrará en índices como el IGM (Índice Global de Madurez).

No se trata de aprobar exámenes, sino de construir un **diagnóstico accionable**:

- No pasa nada por marcar opciones bajas si reflejan la realidad.
- Forzar respuestas “optimistas” sólo sirve para engañar a la hoja de cálculo, no a los atacantes.
- Las opciones con cierto humor no son un chiste: están ahí para aliviar la gravedad del tema, no para restarle importancia.

4. Estructura narrativa de los bloques

4.1. Gobernanza y cultura

Estas preguntas responden a “¿quién manda aquí?” y “¿qué importancia se le da realmente a la ciberseguridad?”. No hay tecnología que compense una gobernanza ausente. Por eso se pregunta por:

- Estrategia formal.
- Implicación del órgano de gobierno.
- Existencia de un responsable claro (CISO o equivalente).
- Alineación con el mapa global de riesgos.

4.2. Marcos de referencia

Este bloque indaga en el “idioma” de la organización:

- ¿Trabaja con NIST, CMMC, ENS, ISO, todo lo anterior o nada de lo anterior?
- ¿Ha hecho autoevaluaciones, mapeos, o vive en estado de yuxtaposición normativa?

Aquí no hay respuestas correctas universales, pero sí se detecta el grado de **alineación con buenas prácticas internacionales**.

4.3. Controles técnicos y operaciones

Los bloques de activos, vulnerabilidades, accesos, protección de datos, monitorización y respuesta son el “esqueleto técnico” de la encuesta. Se exploran aspectos como:

- Visibilidad de activos.
- Velocidad de parcheado.
- Uso de MFA y gestión de identidades.
- Cifrado y control de exfiltración.
- Capacidad de detección y respuesta, métricas incluidas.

En términos de CMMC/NIST, aquí se cruzan varias familias de controles fundamentales.

4.4. Proveedores, documentación y métricas

Porque ninguna organización es una isla:

- Los proveedores pueden ser eslabón fuerte o eslabón débil.
- La documentación (SSP, POA&M, evidencias) es lo que transforma las buenas intenciones en algo auditable.
- Las métricas son el lenguaje que conecta ciberseguridad con estrategia, finanzas y riesgo.

Por eso hay preguntas específicas sobre requisitos contractuales, evaluación periódica de terceros y existencia de índices internos.

5. Lo que la encuesta no es (ni pretende ser)

La encuesta **no es**:

- Una auditoría certificadora en sentido estricto.
- Un sustituto de ensayos técnicos, pentests o supervisión regulatoria.
- Un atajo mágico para lograr CMMC Nivel 3 o el Nirvana ENS Alto.

La encuesta **sí pretende ser**:

- Un punto de partida estructurado para conversaciones serias dentro de la organización.
- Una capa de sensorización que permita comparar, priorizar y argumentar inversiones.
- Un puente entre el lenguaje técnico de CMMC/NIST y el lenguaje de negocio y regulación.

6. Cómo utilizar los resultados sin autoengañarse

Al recibir los resultados (índices, gráficos, rankings internos o sectoriales), conviene:

4. Evitar tanto la euforia (“somos los mejores de nuestra muestra”) como el fatalismo (“somos los peores, quememos los servidores”).
5. Mirar con cuidado los bloques más débiles y preguntarse si son coherentes con los riesgos del negocio.
6. Usar los resultados para construir una hoja de ruta priorizada, no una colección de proyectos inconexos.
7. Volver a repetir la encuesta en el tiempo (por ejemplo, anual) para medir la evolución real, más allá de presentaciones estíves.

7. Y ahora, ¿qué?

Si has llegado hasta aquí, tienes tres opciones:

- Aplicar la encuesta tal cual, y empezar a construir tu propia serie histórica de madurez.
- Adaptarla a tu sector (sanidad, industria exportadora, administración local, etc.), afinando algunos bloques.
- Usarla como excusa para iniciar, con cierta elegancia, una conversación con dirección sobre dónde estáis y adónde queréis llegar.

En todo caso, la encuesta quiere acompañar, no sentenciar. A partir de las respuestas, el verdadero trabajo empieza después.

Fin de la Narrativa Explicativa.

La realidad seguirá ahí cuando cierres este documento; la diferencia es si decides medirla.